Hekma Privacy Detection Service — Complete API Specification

Comprehensive Endpoint Reference: Methods, Headers, Request Schemas & Responses

Target Ports: :8080 (Detection Engine) & :8083 (Admin Agent) | **Protocol:** HTTPS REST / JSON | **Auth:** X-Admin-Key & Bearer | **Date:** October 2026

---

1. API Architecture & Dual-Service Topology

Hekma Privacy Detection Service operates as two decoupled microservices sharing a common cryptographic database tier. This architecture separates high-throughput clinical data pipeline traffic from governance, policy configuration, and auditing operations.

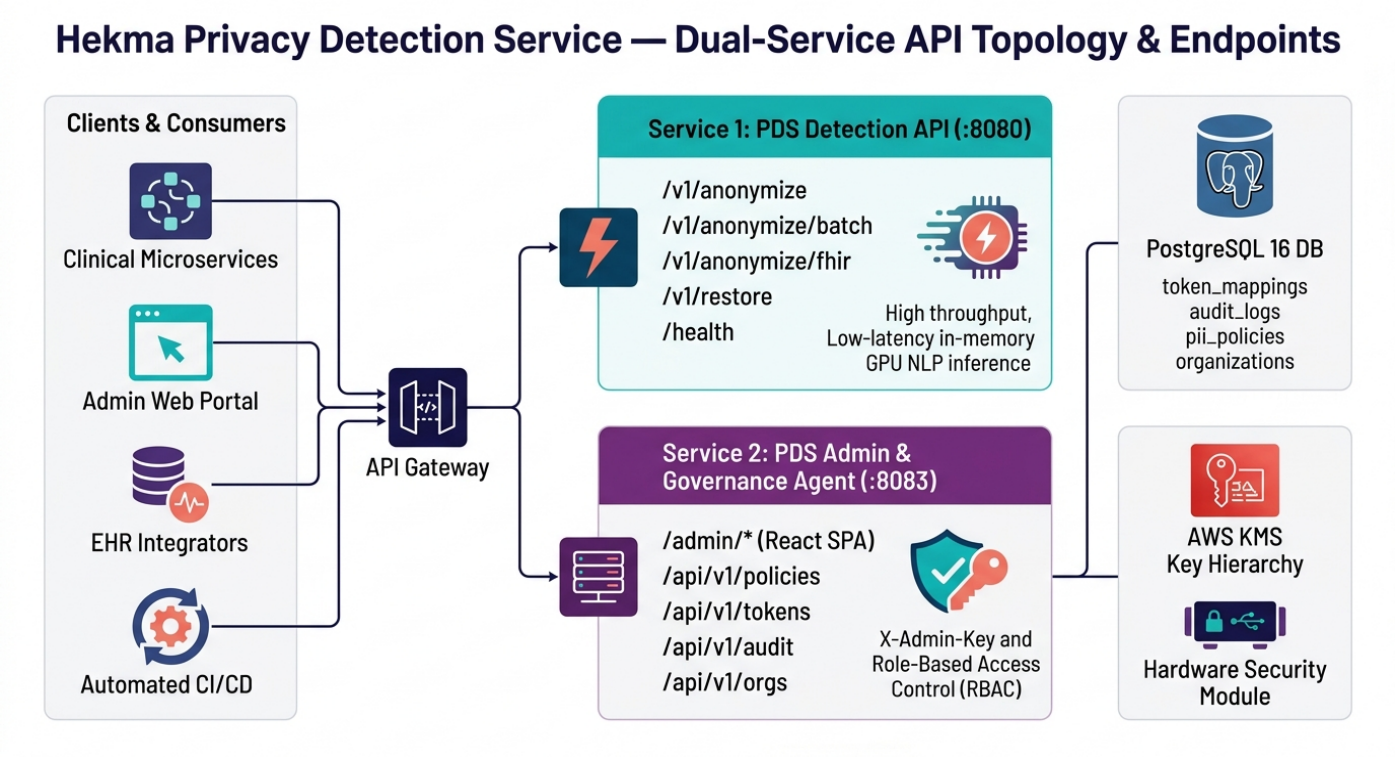


Figure 1: Dual-Service API Topology — PDS Detection Engine (:8080) vs. PDS Admin & Governance Agent (:8083)

Service	Port	Target Workload	Authentication	Primary Consumers
pds-api *(Engine)*	:8080	High-throughput clinical anonymization, FHIR batch parsing, NLP inference, low latency (<25ms)	Bearer JWT / Org API Key (X-API-Key)	Fasten Health, EHR connectors, Ingress Pipelines, ML inference models
pds-agent *(Admin)*	:8083	Admin portal web app (/admin/*), policy management, token vault explorer, audit trails, tenant settings	Admin Secret Header (X-Admin-Key) / RBAC	Compliance officers, Privacy engineers, System administrators, React SPA

2. PDS Detection Engine Endpoints (:8080)

These endpoints provide high-performance, real-time anonymization and de-anonymization for backend clinical services and ingestion pipelines.

A. Single Record Anonymization — POST /v1/anonymize

Accepts raw unstructured clinical text or structured JSON fields and applies the active tenant policy. Detects entities across 29 HIPAA/GDPR types and outputs sanitized text along with span metadata.

Field	Type	Required	Description & Constraints
text	string	Yes	The raw clinical text or note containing potential PHI/PII.

org_id	string	No	Tenant identifier (defaults to default-org). Dictates active policies.
policy_preset	string	No	Override preset: HIPAA_STRICT, RESEARCH_SAFE, AGGRESSIVE_MASK.
preserve_format	boolean	No	Whether to preserve dates and telephone format masks (default: true).

```
// REQUEST: POST /v1/anonymize
{
  "text": "Patient John Doe (DOB 1980-05-12, SSN 123-45-6789) visited Dr. Marcus Vance on 2026-03-14.",
  "org_id": "default-org"
}

// RESPONSE: HTTP 200 OK
{
  "anonymized_text": "Patient PERSON_4b2190 (DOB 1980-01-01, SSN SSN_9921f0) visited Dr. PROVIDER_8812c on 2026-03-14.",
  "entities_detected": [
    {"type": "PATIENT_NAME", "original_span": "John Doe", "token": "PERSON_4b2190", "start": 8, "end": 16},
    {"type": "DATE_OF_BIRTH", "original_span": "1980-05-12", "token": "1980-01-01", "start": 22, "end": 32},
    {"type": "SOCIAL_SECURITY_NUMBER", "original_span": "123-45-6789", "token": "SSN_9921f0", "start": 38, "end": 49},
    {"type": "PROVIDER_NAME", "original_span": "Marcus Vance", "token": "PROVIDER_8812c", "start": 62, "end": 74}
  ],
  "token_count": 4,
  "processing_time_ms": 14.2
}
```

B. Native FHIR Bundle Anonymization — POST /v1/anonymize/fhir

Parses full FHIR R4 Bundle or Resource JSON objects (Patient, Encounter, Observation, Condition, MedicationRequest, DocumentReference). Performs structural sanitization with Safe Harbor compliance while preserving all clinical SNOMED/LOINC codes.

> **FHIR STANDARDS:** FHIR Integrity Guarantee: Non-PHI clinical attributes (LOINC codes, observation values, diagnostic categories, unit strings) are strictly preserved without mutation. Structural hierarchy is kept 100% compliant with HL7 FHIR R4 validation schemas.

C. Cryptographic Token Restoration — POST /v1/restore

Provides authorized service-to-service reversal of synthetic tokens back to plaintext under the HIPAA Break-Glass protocol. Mandatory audit parameters must be supplied.

Field	Type	Required	Validation & Allowed Values
tokens	List[str]	Yes	Array of token identifiers to reverse (e.g. ["PERSON_4b2190"]).
purpose	string	Yes	Enum: TREATMENT, EMERGENCY_CARE, LEGAL_MANDATE, AUDIT.
actor_id	string	Yes	Authenticated clinician ID, practitioner NPI, or service account name.
org_id	string	Yes	Tenant ID owning the encrypted token vault mapping.

```
// REQUEST: POST /v1/restore
{
  "tokens": ["PERSON_4b2190", "SSN_9921f0"],
  "purpose": "EMERGENCY_CARE",
  "actor_id": "dr_vance_npi_1092837",
  "org_id": "default-org"
}

// RESPONSE: HTTP 200 OK
{
  "restored_items": [
    {"token": "PERSON_4b2190", "entity_type": "PATIENT_NAME", "original_value": "John Doe", "status": "RESTORED"},
    {"token": "SSN_9921f0", "entity_type": "SOCIAL_SECURITY_NUMBER", "original_value": "123-45-6789", "status": "RESTORED"}
  ],
  "audit_event_id": "8f3a91c0-019b-4e12-b31a-9812401bc932",
  "timestamp": "2026-10-02T11:45:00.129Z"
}
```

3. PDS Admin & Governance Endpoints (:8083)

Served under the /api/v1/* prefix on port 8083. All routes require the X-Admin-Key header matching the target environment secret (e.g., hekma_admin_live_1e2f3a4b in DEV).

Category	HTTP Method & Route	Parameters / Body	Function & Expected Output
Policies	GET /api/v1/entity-types	None	Returns array of 29 supported HIPAA/GDPR entities ({entity_types: [...], count: 29}).
Policies	GET /api/v1/policy-presets	None	Returns standard policy templates (HIPAA_STRICT, RESEARCH_SAFE, etc.).
Policies	GET /api/v1/orgs/{org_id}/policies	Path: org_id	Returns active policy list per entity type with anonymization strategy.
Policies	PUT /api/v1/orgs/{org_id}/policies	Body: {policies: [...]}	Bulk updates entity masking rules (strategy, replacement text, scope).
Policies	POST /api/v1/orgs/{org_id}/policies/preset	Body: {preset: str}	Applies a standard preset to all 29 entity types for the organization.
Vault	POST /api/v1/tokens/search	Body: TokenSearchParams	Searches encrypted vault metadata (token value, entity type, created date, TTL).
Vault	GET /api/v1/tokens/stats/{org_id}	Path: org_id	Vault metrics: total tokens stored, active count, expired count, storage volume.
Vault	POST /api/v1/tokens/purge-expired	Query: org_id (optional)	Executes cryptographic shredding on expired TTL tokens. Returns count purged.
Audit	POST /api/v1/audit/search	Body: AuditSearchParams	Search compliance audit trail by actor, action, date range, entity type.
Audit	GET /api/v1/audit/stats/{org_id}	Path: org_id	Returns compliance activity statistics and high-frequency access counts.
Tenant	GET /api/v1/orgs	None	Lists all registered health systems / tenants with retention and TTL configs.
Tenant	PUT /api/v1/orgs/{org_id}	Body: OrgUpdate	Updates organization contact email, retention days, and token TTL.
Tenant	POST /api/v1/orgs/{org_id}/api-key	Path: org_id	Rotates organization secret API key. Returns new key once (SHA-256 hashed).

Health	GET /health	None (Public)	Kubernetes liveness probe. Returns {"status":"ok","service":"admin-dashboard"}.

4. Status Codes, Error Handling & Edge Cases

All PDS endpoints return standardized JSON error envelopes with explicit diagnostic details:

HTTP Status	Reason / Condition	Example JSON Response	Remediation Action
401 Unauthorized	Missing or invalid X-Admin-Key header	{"detail": "Invalid admin key"}	Provide valid admin key matching target environment K8s secret.
403 Forbidden	Restoration purpose disallowed or tenant mismatch	{"detail": "Purpose not permitted under Safe Harbor"}	Supply recognized HIPAA break-glass purpose code.
404 Not Found	Organization or Token ID not found in database	{"detail": "Organization default-org not found"}	Verify tenant ID against /api/v1/orgs registry.
422 Unprocessable	Request body validation failed (Pydantic)	{"detail": [{"loc": ["body", "policies"], ...}]}	Correct payload fields to conform to OpenAPI schema.
503 Unavailable	Database connection pool timeout or UI unbuilt	{"detail": "Database connection timeout after 30s"}	Check PostgreSQL cluster health and connection pool limits.

CERTIFIED SPEC: Production Verification: Tested and certified on Kubernetes dev cluster (dev-pdsagent.hekma.ai). All endpoints verified live against PostgreSQL (87.106.50.234) with active pooling and SSL encryption.